

MODULE 06 · DOMAIN 2 - SECURITY AND COMPLIANCE

IAM and Access Management

Who can do what, to which resource, under which conditions.

DOMAIN 2 of 4 EXAM WEIGHT 30% MODULE 6 of 26

Every IAM question is asking one thing: **who**
can do **what**, to **which resource**.

The four building blocks

OBJECT	WHAT IT IS
User	A single identity with long-term credentials. A person or an application.
Group	A collection of users. You attach policies to it, not sign in as it.
Role	An identity assumed temporarily. No password, no permanent keys.
Policy	A document saying which actions are allowed or denied on which resources.

ON THE EXAM

Users and roles are identities. Groups are a convenience for managing users. Policies are the permissions themselves.

User or role?

IAM USER

Long-term identity

- Has a password or access keys that persist
- Belongs to one person or application
- Credentials must be rotated by you
- Suits a human who signs in regularly

IAM ROLE

Temporary identity, assumed

- Credentials are issued on demand and expire
- Assumed by users, applications or AWS services
- Nothing to rotate, nothing to leak
- The answer for EC2, Lambda and cross-account

THE TIEBREAKER

If an application or an AWS service needs permissions, the answer is a role. Never store access keys on an instance.

The root user

- ◆ **Created when the account is created.** It signs in with the email address, not a username.
- ◆ It has complete, unrestricted access. IAM policies cannot restrict it.
- ◆ Create an administrative user for daily work and lock the root user away.
- ◆ Delete any root access keys. There is no legitimate reason for the root user to have them.
- ◆ **A small set of tasks require it**, and those are what the exam asks about.

ON THE EXAM

IAM policies and service control policies cannot limit the root user of a standalone account. That is why you stop using it.

Tasks only the root user can do

- ◆ Change the account name, email address or root password.
- ◆ Change or cancel the AWS Support plan.
- ◆ Close the AWS account.
- ◆ Restore IAM user permissions when an administrator has locked everyone out.
- ◆ Enable MFA delete on an S3 bucket, and register as a seller in the Reserved Instance Marketplace.

ON THE EXAM

The pattern is account-level, not resource-level. Anything that changes the account itself needs root.

Multi-factor authentication

- ◆ **MFA adds a second factor** to the password: a virtual authenticator, a hardware token, or a passkey.
- ◆ AWS supports FIDO2 passkeys and security keys, which resist phishing better than one-time codes.
- ◆ **Study material calls root MFA a best practice. It is now enforced.**
- ◆ Management accounts from May 2024, standalone from June 2024, member accounts from June 2025.
- ◆ On the exam, answer that enabling MFA on the root user is the recommended first action. That is still correct.

ON THE EXAM

Reality moved from recommended to mandatory. The exam answer did not change, because enabling it is still what you do.

Identity-based or resource-based?

IDENTITY-BASED POLICY

Attached to who is asking

- Attached to a user, group or role
- Says what that identity may do
- The common case by far
- No principal named; the identity is the principal

RESOURCE-BASED POLICY

Attached to the thing being asked for

- Attached to a resource, such as an S3 bucket
- Names the principal explicitly
- Enables cross-account access without a role
- S3 bucket policies are the classic example

THE TIEBREAKER

Attached to an identity means identity-based. Attached to a bucket, queue or key means resource-based.

The three identity-based policy types

TYPE	WHEN YOU USE IT
AWS managed	Created and maintained by AWS. ReadOnlyAccess, AdministratorAccess.
Customer managed	You write it. Reusable across many identities, and versioned.
Inline	Embedded in one identity. Strictly one-to-one, deleted with the identity.

THE TIEBREAKER

Applies to exactly one user, group or role means inline. Reusable across several means customer managed.

How a request is evaluated

01

Default deny

Every request starts denied. Nothing is permitted implicitly.

02

Look for an allow

An applicable allow in any policy changes the result to allowed.

03

Look for a deny

Any explicit deny anywhere overrides every allow.

04

Result

Allowed only if something allowed it and nothing denied it.

ON THE EXAM

Explicit deny always wins. Adding an allow can never override a deny, no matter where the deny came from.

Least privilege

- ◆ **Grant only the permissions required to perform a task**, and nothing more.
- ◆ Start from the minimum and add. Do not start from AdministratorAccess and trim.
- ◆ Use groups so permissions follow a job function rather than an individual.
- ◆ Attaching AdministratorAccess because it is quicker is always the wrong answer on this exam.
- ◆ Review permissions periodically. People change roles and keep old access.

ON THE EXAM

When two options both work and one grants less, the one granting less is correct. This exam never rewards convenience.

IAM or IAM Identity Center?

AWS IAM

Inside a single account

- Users, groups, roles and policies
- Permissions within one AWS account
- The default answer for permissions questions
- Long-lived users, or roles for temporary access

IAM IDENTITY CENTER

Across many accounts

- One sign-in to many AWS accounts
- Connects an existing corporate directory
- Workforce single sign-on
- Formerly called AWS Single Sign-On

THE TIEBREAKER

One account means IAM. Multiple accounts, workforce sign-on, or an existing directory means IAM Identity Center.

IAM or Amazon Cognito?

AWS IAM

People who use AWS

- Employees, administrators, engineers
- Sign in to the console or call the API
- Numbered in tens or hundreds
- Managing your AWS account

AMAZON COGNITO

People who use your application

- Customers signing in to your app or website
- Sign-up, sign-in, social and enterprise identity providers
- Numbered in thousands or millions
- Never touches your AWS console

THE TIEBREAKER

If the users are your customers, it is Cognito. If they are your staff working in AWS, it is IAM.

Federation and directory services

- ◆ **Federation lets people use an existing identity** to access AWS, rather than a new IAM user.
- ◆ The corporate directory stays the source of truth. Joiners and leavers are handled once.
- ◆ **AWS Directory Service** provides managed Microsoft Active Directory in AWS.
- ◆ Federated users assume a role, which is why they get temporary credentials.
- ◆ The exam signal is an existing on-premises directory the company does not want to duplicate.

ON THE EXAM

Do not create IAM users for people who already exist in a corporate directory. Federate instead.

IAM Access Analyzer

- ◆ **External access findings.** Which resources are shared with an outside account or the public.
- ◆ **Unused access findings.** Roles, access keys, passwords and permissions nobody has used.
- ◆ That second capability is how you detect over-granted permissions and enforce least privilege over time.
- ◆ It can also generate a policy from observed CloudTrail activity.
- ◆ It analyses permissions. It does not detect threats; that is GuardDuty.

ON THE EXAM

Unused permissions or unintended external sharing means IAM Access Analyzer. Both phrases point at the same service.

Credentials and hygiene

- ◆ **Access keys are for programmatic access.** A password is for the console. They are not interchangeable.
- ◆ Rotate access keys regularly and delete ones nobody uses.
- ◆ Never embed access keys in code, in an AML, or in a public repository.
- ◆ **A password policy** sets minimum length, complexity, expiry and reuse rules for IAM users.
- ◆ Prefer roles over keys wherever a role is possible. Then there is nothing to rotate.

ON THE EXAM

The best answer to a credential-leak question is usually to stop using long-term credentials at all.

An application running on an Amazon EC2 instance needs to read objects from an Amazon S3 bucket. A developer has created an IAM user for the application, generated access keys, and written them into a configuration file on the instance.

A security review flags this as an anti-pattern and asks for a better approach.

What should the company do instead?

- ☐ A Rotate the access keys every thirty days
- ☐ B Attach an IAM role to the EC2 instance
- ☐ C Encrypt the configuration file containing the keys
- ☐ D Move the access keys into an environment variable

◆ PAUSE AND DECIDE

What should the company do instead?

- A

 Rotate the access keys every thirty days
Good hygiene, but the keys still exist on the instance for thirty days at a time. It reduces the window, not the flaw.
- C

 Encrypt the configuration file
The application must decrypt it to use it, so the key material is still reachable on the instance.
- B

 Attach an IAM role to the EC2 instance
Temporary credentials are delivered and rotated automatically. There are no long-term keys to leak.
- D

 Move the access keys into an environment variable
Moves the secret somewhere else on the same machine. Nothing has actually improved.

THE SIGNAL

An AWS service needing permissions is always a role. Options A, C and D all keep the long-term key and manage it better.

A company needs to create a permission set that applies to exactly one IAM user, a contractor with unusual access requirements that no other person in the company has or will have.

The security team wants the permissions removed automatically if that user is ever deleted.

Which policy type meets this requirement?

- ☐ A An AWS managed policy
- ☐ B A customer managed policy
- ☐ C An inline policy
- ☐ D A resource-based policy

◆ PAUSE AND DECIDE

Which policy type meets this requirement?

- A

 An AWS managed policy
Written by AWS for common use cases. It cannot express one contractor's unusual requirements.
- B

 A customer managed policy
The strongest distractor. It expresses the permissions fine, but it persists after the user is deleted.
- C

 An inline policy
One-to-one with a single identity, and deleted along with it. Both requirements met.
- D

 A resource-based policy
Attaches to a resource rather than an identity. Wrong place entirely for a per-user permission set.

THE SIGNAL

Two requirements: exactly one identity, and deleted with it. Only inline satisfies the second.

A user belongs to a group with a policy allowing all Amazon S3 actions. The user also has an inline policy that explicitly denies deleting objects in one particular bucket.

An administrator additionally attaches AdministratorAccess directly to the user, hoping to resolve a support ticket quickly.

Can the user now delete objects in that particular bucket?

- ☐ A Yes, because AdministratorAccess allows all actions
- ☐ B Yes, because the group policy allows all S3 actions
- ☐ C No, because the explicit deny overrides both allows
- ☐ D It depends which policy was attached most recently

◆ PAUSE AND DECIDE

Can the user now delete objects in that particular bucket?

- A

 Yes, because AdministratorAccess allows all actions
The trap. AdministratorAccess is still just an allow, and an allow never beats an explicit deny.
- B

 Yes, because the group policy allows all S3 actions
Also just an allow. Permissions accumulate, but a deny is not outvoted by more allows.
- C

 No, because the explicit deny overrides both allows
Explicit deny wins over every allow, from any policy, regardless of how broad.
- D

 It depends which policy was attached most recently
Order of attachment is irrelevant. Evaluation is not chronological.

THE SIGNAL

Explicit deny always wins. No amount of additional allow, including full administrator access, changes that.

An engineering firm of four hundred staff already runs Microsoft Active Directory on premises. It is opening twelve AWS accounts, one per project team, and wants staff to sign in to whichever accounts they are entitled to using their existing corporate credentials.

The identity team does not want to create or maintain separate credentials in each AWS account.

Which service meets these requirements?

- ☐ A Create IAM users in each of the twelve accounts
- ☐ B AWS IAM Identity Center
- ☐ C Amazon Cognito
- ☐ D An IAM group in the management account

◆ PAUSE AND DECIDE

Which service meets these requirements?

- A

 Create IAM users in each of the twelve accounts
Four hundred staff times twelve accounts, all needing joiner and leaver handling. Exactly what the firm ruled out.
- B

 AWS IAM Identity Center
Connects the existing directory and grants access across many accounts from one sign-in.
- C

 Amazon Cognito
For application end users, not staff signing in to AWS accounts. Wrong population.
- D

 An IAM group in the management account
Groups organise users inside one account. They do not span accounts or connect a directory.

THE SIGNAL

Three signals: many accounts, existing corporate directory, no duplicate credentials. All point one way.

A security team is asked two questions by an auditor. First, are any S3 buckets or IAM roles in the account accessible from outside the organisation? Second, which IAM roles and access keys have not been used in the last ninety days?

The team wants a single service that answers both.

Which service should the team use?

- | | |
|--|--|
| ☐ A Amazon GuardDuty | ☐ B AWS CloudTrail |
| ☐ C IAM Access Analyzer | ☐ D AWS Trusted Advisor |

◆ PAUSE AND DECIDE

Which service should the team use?

- A

 Amazon GuardDuty
Detects threats and malicious behaviour. It does not audit who could access what.
- B

 AWS CloudTrail
Records what was done. Answers the second question with a lot of analysis, and the first not at all.
- C

 IAM Access Analyzer
External access findings answer the first; unused access findings answer the second.
- D

 AWS Trusted Advisor
Flags some public resources among its best-practice checks, but reports nothing about unused permissions.

THE SIGNAL

The two questions map exactly onto Access Analyzer's two capabilities. That is why one service covers both.

What to carry out of this module

- ◆ **Sort every question into who, what, which resource.** The answer usually falls out.
- ◆ **An application or AWS service needing permissions is always a role.** Never keys on an instance.
- ◆ **Explicit deny always wins.** No amount of additional allow overrides it.
- ◆ Inline means exactly one identity, and deleted with it. Customer managed is reusable and persists.
- ◆ Many accounts or a corporate directory means IAM Identity Center. Your app's customers means Cognito.

ON THE EXAM

When two options both work and one grants less access, the one granting less is correct.